

SEUSL Smart Lost and Found Management System

Final Technical, Academic, Security and AI Project Report

Nisala (GitHub: nisalajuriance)
Heshan (GitHub: Heshan-3)

Dinuka (GitHub: dinukahansana)
Janidu (GitHub: janidu200301)

26 July 2026

Contents

1 Declaration and report status	2
2 Executive summary	2
3 Problem statement	3
3.1 Fragmented discovery	3
3.2 Privacy and safety	3
3.3 Weak verification	3
3.4 Language and location complexity	4
3.5 Operational reliability	4
4 Objectives	4
5 Scope and actors	4
5.1 Actors	4
5.2 Out of scope or prohibited	5
6 System architecture	5
6.1 Frontend	5
6.2 Backend	6
7 Database design	6
7.1 Users and sessions	6
7.2 Lost and found reports	6
7.3 Matches	7
7.4 Claims	7
7.5 Outbox, notifications, AI and location	7
8 Authentication and security architecture	7
8.1 Input and file security	7
8.2 Privacy serializers	7
8.3 State and transaction safety	8
9 AI capabilities and governance	8
9.1 Image intelligence	8
9.2 Multilingual chatbot and search	8
9.3 Matching	8

9.4 Location intelligence	9
9.5 Report/claim assistance	9
9.6 Fraud and safety	9
9.7 Provider failover and monitoring	9
10 Claim and handover workflow	9
11 Notification and background processing	9
12 User interface and accessibility	10
12.1 Core changes	10
12.2 Space animation	11
12.3 Accessibility target	11
13 Administration and operations	11
14 Testing and verification	12
15 Privacy, ethics and responsible AI	12
16 Public-launch documentation	12
17 Production acceptance status	13
18 Limitations and future work	13
19 Conclusion	13
20 Document references	13

1 Declaration and report status

This report describes the current hardened release candidate of the SEUSL Smart Lost and Found Management System. It replaces the earlier five-page report whose authentication, AI, matching, contact-sharing, and production-readiness descriptions no longer matched the source code.

The project has completed extensive source-level security, workflow, AI, multilingual, accessibility, user-interface, documentation, and release-hygiene improvements. A software system cannot honestly be guaranteed to be defect-free or described as fully production-certified until the exact deployment passes the infrastructure-dependent gates listed in Section 16. This report therefore distinguishes implemented source controls from external production acceptance.

The official approval, service-owner contact, privacy officer, hosting region, processor register, retention periods, credentials rotation, and UAT signatures must be completed by authorised university officers before public launch.

2 Executive summary

Lost-property management in a university is often fragmented across offices, paper registers, messaging groups, social-media posts, security desks, and informal

student networks. This creates poor searchability, duplicated reports, privacy exposure, slow communication, weak ownership verification, and opportunities for fraudulent claims.

The SEUSL Smart Lost and Found Management System is a MERN-based, AI-assisted, privacy-aware platform for reporting, searching, matching, claiming, verifying, and safely returning property. It supports English, Sinhala, and Tamil interface modes, and the chatbot also understands natural Singlish and Tamilish. The system preserves the project's distinctive animated space visual identity while adapting effects for reduced-motion preferences and lower-power mobile devices.

The solution goes beyond a basic CRUD application. It includes:

- secure cookie-based authentication with rotating hashed refresh sessions and reuse detection;
- role-aware public/private data serializers;
- guided lost/found report and edit workflows with optional AI image assistance;
- multilingual all-result chatbot search with context, ranking, pagination, useful clarification, and grounded actions;
- explainable lost/found matching based on multiple bounded signals;
- private claim evidence and transactional human approval/handover workflows;
- durable outbox jobs, real-time notifications, email, and optional push;
- internal SEUSL/Oluvil/Sammanthurai regional micro-location knowledge without requiring a visible map;
- community location corrections and administrative verification;
- AI usage, feedback, provider failover, quality checks, duplicate detection, and human-review-only fraud prioritisation;
- public legal/accessibility pages, complete technical/academic documentation, OpenAPI, diagrams, SBOM, and release controls.

3 Problem statement

Traditional university lost-and-found processes have five major weaknesses.

3.1 Fragmented discovery

A person who loses an item may post in several groups, ask security staff, visit faculty offices, and search notice boards. A finder may use completely different channels. Matching depends on chance rather than a consistent searchable record.

3.2 Privacy and safety

Public messages frequently expose student names, phone numbers, identifiers, precise routines, and complete ownership details. These can be used for spam, harassment, identity misuse, or false claims.

3.3 Weak verification

A public item description alone is insufficient to prove ownership. High-value items require private distinguishing details, evidence, reporter judgement, and a controlled handover.

3.4 Language and location complexity

SEUSL users may write in English, Sinhala, Tamil, Singlish, Tamilish, or mixed language. Locations are described through official names, student nicknames, local spellings, villages, junctions, shops, lanes, bus stops, and landmarks. Exact keyword search produces poor results.

3.5 Operational reliability

Email, AI, media, Redis, or worker failures must not silently corrupt claim states. Multiple server instances must not run destructive or duplicated jobs. Administrators need measurable queues, audit history, backup/restore, and release evidence.

4 Objectives

The project objectives are to:

1. centralise lost and found reports;
2. provide fast, multilingual and privacy-safe search;
3. assist report creation using optional image and language AI;
4. produce explainable, bounded match suggestions;
5. preserve all relevant results rather than returning a single arbitrary report;
6. support internal micro-location reasoning for campus and surrounding communities;
7. protect contact and private ownership evidence;
8. require human ownership and handover decisions;
9. prevent duplicate/racing workflow corruption using transactions and indexes;
10. provide reliable notification and background processing;
11. provide accessible mobile/desktop interfaces;
12. give administrators operational, safety, and AI-quality controls;
13. document privacy, security, retention, incident, backup, UAT, and release responsibilities;
14. remain usable when optional AI or push providers are unavailable.

5 Scope and actors

5.1 Actors

- Public visitor: searches public-safe reports and reads service policies.
- Student/staff user: reports, searches, receives matches, submits claims, confirms handover, corrects locations, manages account.
- Reporter/finder: reviews claims, controls contact visibility, verifies ownership, performs safe handover.
- Administrator: manages users, reports, claims, matches, categories, locations, settings, audit logs, AI metrics, and review queues.
- University service owner: approves policy, risk, retention, contacts, providers, UAT, and production release.
- IT/security/privacy/accessibility staff: operate, monitor, test, respond to incidents, and review compliance.
- External providers: optional approved media, email, OAuth, push, AI, mapping/place, database, and hosting services.

5.2 Out of scope or prohibited

- AI ownership decisions;
- face identification or sensitive-trait inference;
- automated disciplinary action or account bans;
- public CCTV/security blind spots or sensitive infrastructure;
- public exact private-room/residence locations;
- bulk scraping/copying restricted third-party mapping content;
- advertising and sale of user data.

6 System architecture

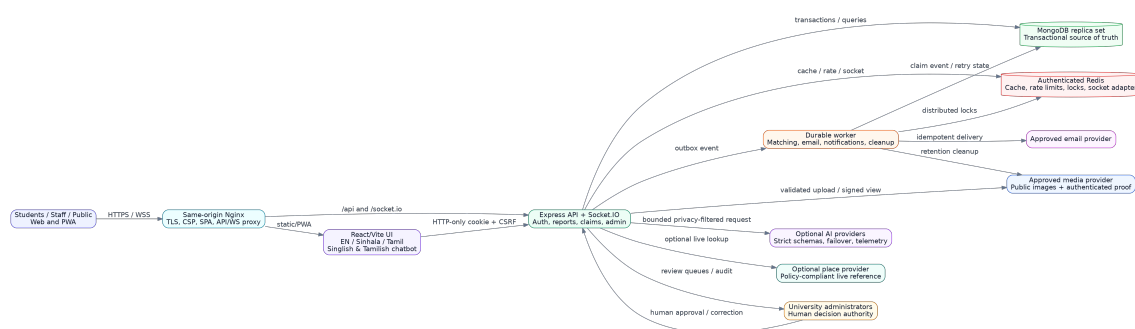


Figure 1: System architecture

The React/Vite application is served through a same-origin Nginx layer that proxies REST and Socket.IO traffic to the Express service. A MongoDB replica set is the transactional source of truth. Redis provides cache, rate-limit, distributed lock, and Socket.IO adapter functions. Durable outbox records preserve asynchronous work across restarts. Optional providers supply media, email, push, Google sign-in, AI inference, and place lookup.

The production architecture is fail-closed: required providers and transaction support must be ready before the service reports production readiness. Optional AI can be disabled while manual reporting and deterministic search remain available.

6.1 Frontend

The frontend uses React, Redux Toolkit, React Router, Tailwind-based styling, reusable accessible components, a service layer, and PWA support. Important design changes include:

- task-first navigation and mobile centre report action;
- base typography increased for Sinhala/Tamil and mobile readability;
- focus-managed dialogs and keyboard-operable controls;
- guided report and claim workflows;
- structured chatbot result cards and show-more pagination;
- explainable match comparison;
- attention-first user/admin dashboards;
- public privacy, terms, and accessibility routes;
- preserved adaptive space animation with reduced-motion/static fallback.

6.2 Backend

The backend separates routes, validation, controllers, models, services, jobs, serializers, and configuration. Important services include session management, media, email, notifications, language, location knowledge, image analysis, report intelligence, matching, fraud-risk prioritisation, account anonymisation, item workflows, outbox processing, and distributed jobs.

7 Database design

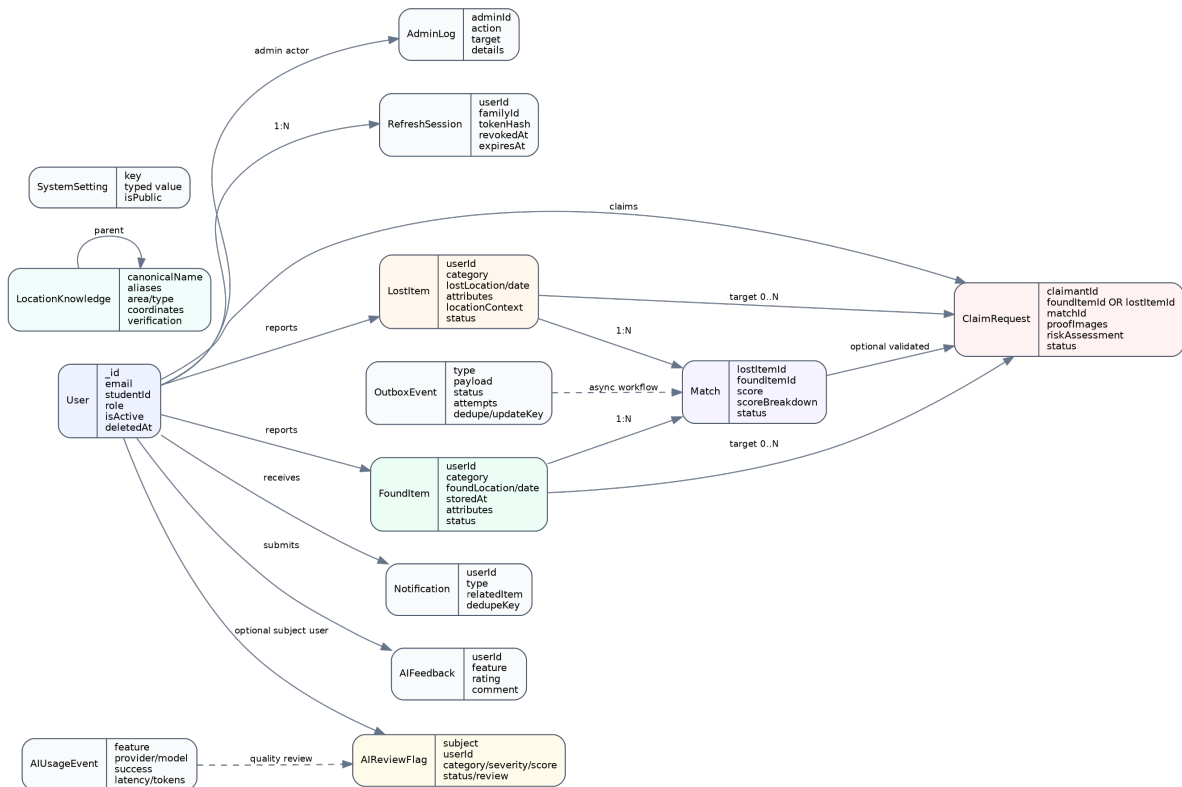


Figure 2: Entity relationship overview

The main entities are documented in docs/academic/ER_AND_DATA_DICTIONARY.md.

7.1 Users and sessions

Users store account/profile state but not plaintext refresh tokens. Refresh sessions store token hashes, family relationships, expiry, revocation, and reuse state. Password/verification/reset secrets are hashed and selected only where necessary.

7.2 Lost and found reports

Reports contain category, privacy-safe descriptions/images, date/time, location, contact preferences, searchable tags, rich item attributes, AI-source metadata, location context, ownership, state, and relationship fields. Public serializers omit hidden contact, student identifiers, connection state, and internal metadata.

7.3 Matches

Each match links one lost and one found report with a unique pair index, score, breakdown, reasons, status, users, and notification state. Rejected suggestions remain rejected unless an explicit authorised workflow changes them.

7.4 Claims

A claim targets exactly one lost or found report and may reference one validated match. It stores claimant, private ownership description, authenticated proof images, status, contact-sharing state, reviewer, and AI-assisted risk assessment. Unique partial indexes prevent duplicate active pending claims.

7.5 Outbox, notifications, AI and location

Outbox events provide durable idempotent work. Notifications use dedupe keys. AI usage and feedback provide bounded quality telemetry. AI review flags prioritise human review only. LocationKnowledge stores canonical names, multilingual/local aliases, hierarchy, source, confidence, coordinates when approved, privacy status, and reviewer history.

8 Authentication and security architecture

The original project stored access and refresh tokens in browser localStorage and a single plaintext refresh token on the user record. The hardened implementation uses:

- HTTP-only access and refresh cookies;
- CSRF cookie/header pair for state-changing requests;
- hashed refresh-session records;
- rotation with session families and concurrent reuse revocation;
- exact allowed origins instead of broad wildcard Vercel acceptance;
- role checks that reload active users;
- strong password policy, logout, hashed verification/reset tokens;
- Google email-verification checks;
- session revocation after password, role, status, or account changes.

Production configuration rejects weak/missing required secrets and unsafe local-host/HTTP allowances unless explicit development overrides are used.

8.1 Input and file security

Request body, query, parameter, and multipart fields are validated and bounded. Images are limited by size/count/MIME and magic bytes. Public item images and private claim evidence use separate media delivery rules. Claim evidence uses authenticated assets and short-lived authorised views.

8.2 Privacy serializers

Reporter email, phone, student ID, profile details, connected user, and internal metadata are never populated into anonymous/public responses without an ex-

licit safe serializer decision. Public contact reveals only the user-selected channel. Claim views distinguish claimant, reporter, admin, and outsider permissions.

8.3 State and transaction safety

General item updates cannot set workflow status. Claim approval, reciprocal reports, competing claims, match state, categories, role/status changes, and critical account operations use transactions where applicable. Unique indexes provide database-level invariants.

9 AI capabilities and governance



Figure 3: AI data flow

The completed AI scope includes the original chatbot, matching, category/icon creation, image recognition, and auto-fill behaviour, plus advanced capabilities.

9.1 Image intelligence

The image assistant can suggest item name, category/icon, description, tags, colours, brand, model, material, unique marks, privacy-safe visible text, quality, and confidence. It rejects or warns about blank, unrelated, explicit, selfie/face, identity/card, or unsafe images. Suggestions are presented field-by-field for user review and never silently become authoritative.

9.2 Multilingual chatbot and search

The chatbot supports English, Sinhala, Tamil, Singlish, Tamilish, and mixed input. It performs Unicode normalisation, intent detection, synonym expansion, location resolution, broad candidate retrieval, weighted ranking, result count, pagination, facets, context refinement, personal authenticated queries, actions, sources, reasons, and optional grounded provider wording.

The earlier exact \$and keyword query and one-report response limitation were removed. The assistant asks a clarification only when it materially changes the answer, for example distinguishing the main library from the Science Library.

9.3 Matching

The matching service uses bounded recent opposite-report candidates and combines category, multilingual text/synonyms, date plausibility, location similarity, colours, visual metadata, and item attributes. It stores explainable reasons and score breakdown. Strong matches create one-time notifications through durable processing.

9.4 Location intelligence

A visible map is not required. The internal location layer understands verified campuses, faculties, buildings, services, Oluvil/Palamunai/Addalaichenai/Akkaraipattu/Sammanthura areas, roads, junctions, lanes, shops, bus stops, landmarks, and local aliases. Community corrections require admin verification. Optional live provider results remain a reference and do not automatically become authoritative.

9.5 Report/claim assistance

The service provides report completeness suggestions, possible duplicate reports, category-aware private ownership questions, claim evidence quality guidance, and AI-assisted fraud/abuse review priorities.

9.6 Fraud and safety

Risk scoring may consider unusual pending/recent/rejected claim frequency, weak distinguishing information, and reused evidence hashes. It creates a human-review flag with reasons. It does not auto-ban, auto-reject, or establish ownership.

9.7 Provider failover and monitoring

Multiple configured keys/models can be attempted with timeout and strict response validation. Usage records feature, provider/model, success, latency, and tokens without normal raw private proof. Feedback records helpful, incorrect, or unsafe outcomes. Admins can disable AI while preserving manual/deterministic operation.

10 Claim and handover workflow

1. A claimant selects a target item and optionally supplies a related match.
2. The API verifies that the match, target, and claimant relationship are exact.
3. Private description/evidence is validated and stored using authenticated delivery.
4. Duplicate active claims and rate limits are enforced.
5. AI may create a human-review risk priority; it takes no enforcement action.
6. Reporter/admin reviews evidence and may share contact or request more information.
7. Approval runs transactionally, marks the item in progress, validates reciprocal match/report relationships, and rejects competing pending claims.
8. Parties arrange a safe physical handover.
9. Required participants confirm the handover, after which retention/archive rules apply.

Email, push, or Socket.IO failure after a business transaction does not roll back the committed claim state; side effects are retried/deduplicated.

11 Notification and background processing

Notifications use the correct user room and related-entity schema. Email has a complete template registry; unknown templates fail closed. Verification/reset links

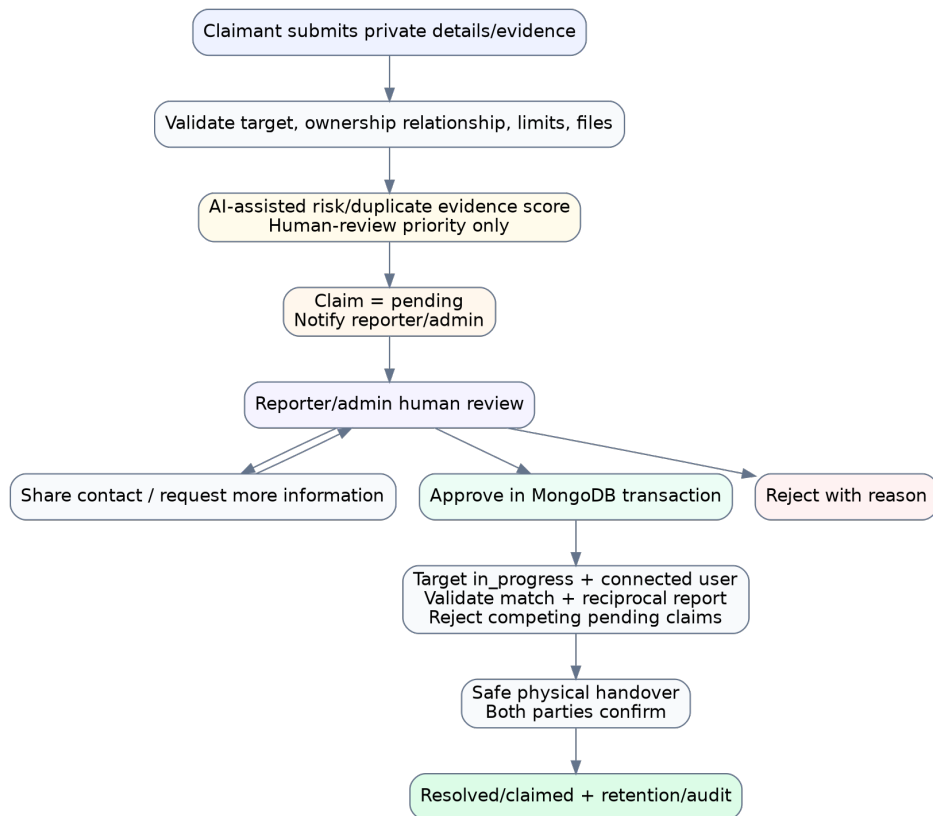


Figure 4: Claim workflow

are not logged. Provider requests use idempotency where supported.

Background matching, email/notification work, retries, and cleanup use durable outbox/worker records. Redis/distributed locks prevent every application instance from running the same scheduled job. Cleanup retains database references when provider media deletion fails so a later retry remains possible.

12 User interface and accessibility

The UI redesign aims to be simple for a first-year student, credible for a university service, readable on low-end phones, multilingual, and transparent about AI uncertainty.

12.1 Core changes

- Home page prioritises Report Lost, Report Found, and Search.
- Report and edit forms share a four-step wizard.
- AI suggestions show confidence and Apply/Ignore controls.
- Search lists show total results, filters, ranking and pagination.
- Item details show rich characteristics, AI/user source, location confidence, and recovery timeline.
- Match cards compare both reports and explain why they match.
- Claims use a private evidence/review stepper.

- User dashboard shows needed attention before optional installation/push prompts.
- Admin dashboard and AI review queue prioritise operational work.

12.2 Space animation

The project's space animation is preserved as a signature identity. It adapts particle count, resolution and effects to device capability, pauses in background tabs, limits device-pixel ratio, uses a static/reduced form when prefers-reduced-motion is enabled, and remains decorative to assistive technology.

12.3 Accessibility target

The target is WCAG 2.2 AA. Foundations include semantic landmarks, skip navigation, visible focus, touch-sized actions, labelled native controls, focus-trapped dialogs, error summaries, live status announcements, reflow/zoom, reduced motion, and manual fallback. Independent deployed accessibility UAT remains a release gate.

13 Administration and operations

Administrators can manage users, reports, matches, claims, categories, locations, settings, feedback, logs, AI metrics, and human-review flags. Concurrent last-admin protections prevent accidental removal of all active administrators. Account deletion uses anonymisation and workflow cleanup rather than unsafe unconditional hard deletion.

Operational readiness reports MongoDB transaction support and required providers. The source includes migration, non-destructive default seeding, explicit admin bootstrap, Docker/Compose definitions, CI, CodeQL/dependency-review workflows, backup/DR, incident response, and release approval templates.

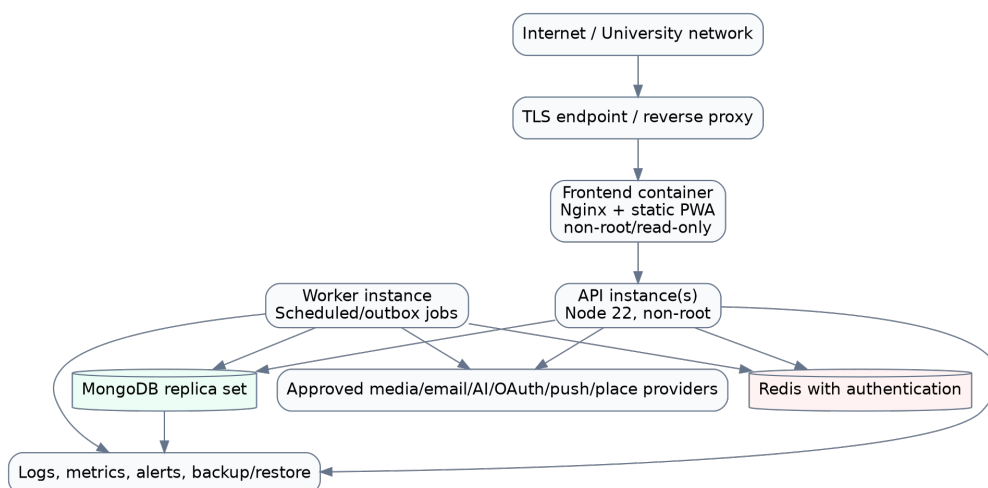


Figure 5: Deployment overview

14 Testing and verification

The local/source validation performed for this release includes:

- JavaScript syntax checks across backend source;
- backend unit/security/language/location/AI/fraud tests;
- frontend ESLint with zero warnings;
- frontend security tests;
- JSON/YAML/OpenAPI parsing;
- relative-import and secret-pattern checks;
- lockfile-derived SBOM/licence inventory;
- release hygiene excluding `.env`, `.git`, `node_modules`, stale build output and development junk.

One live MongoDB replica-set concurrent session test is designed to skip when no replica-set server is available. Clean Linux build, Docker, live providers, DAST, restore, load/soak, browser/accessibility UAT, and deployment monitoring remain external gates.

Detailed test cases are in `docs/academic/TEST_PLAN_AND_CASES.md` and evidence is in `evidence/`.

15 Privacy, ethics and responsible AI

The design separates public item recognition from private ownership proof. It minimises exact private locations, requires user review of AI output, provides correction/feedback, prevents AI enforcement, and documents processors/retention. It deliberately prohibits face identification and sensitive-trait inference.

Potential ethical risks include language bias, location-data incompleteness, overconfidence in match scores, unequal access to quality images/connectivity, and false fraud flags. Controls include multilingual UAT, confidence/explanation, manual alternatives, human review, no automatic enforcement, source/confidence status, and accessible support.

16 Public-launch documentation

The release includes:

- Privacy and Student Data Notice;
- Terms and Acceptable Use;
- Cookie/Session and Retention notices;
- Processor register;
- Accessibility and AI transparency statements;
- User/Admin/Support manuals;
- SRS, Design, ER/Data Dictionary, Test Plan, UAT template, DPIA;
- Backup/DR, Incident Response, Operating Runbook, Approval Checklist;
- OpenAPI specification;
- architecture, ER, claim, AI and deployment diagrams;
- SBOM and dependency licence inventory;
- security, deployment, migration, verification, completion and certification reports.

17 Production acceptance status

The source-level and available-environment hardening is substantial, but production approval requires the exact target environment to pass:

1. clean Linux backend/frontend dependency installation and production build;
2. MongoDB replica-set migration and concurrency/integration tests;
3. Docker/Compose build, non-root/read-only and health smoke tests;
4. real media, email, OAuth, push, AI and optional place provider tests;
5. HTTPS staging cookie/CSRF/CORS/CSP/WebSocket verification;
6. SAST/dependency/secret/container/DAST scans with no unaccepted critical/high findings;
7. backup and restore drill, rollback, load, soak, failure recovery;
8. browser/mobile and WCAG 2.2 AA UAT;
9. processor, retention, contact, privacy, risk, and institutional approvals;
10. rotation and invalidation of any credential previously included in archives/history.

A signed docs/academic/UAT_AND_APPROVAL_SIGNOFF_TEMPLATE.md and docs/release/PRODUCE are required before the words “production approved” are used.

18 Limitations and future work

- Exact unmapped lanes, temporary businesses, boarding places, and local nicknames require field/community verification.
- Browser speech recognition support varies; text remains the reliable fallback.
- AI accuracy must be measured on an approved representative dataset before publishing accuracy claims.
- Advanced offline-first image upload, native mobile applications, institutional SSO, admin MFA, vector/image embeddings, and independently hosted models are future enhancements subject to privacy/security review.
- No system can guarantee perfect retrieval, zero fraud, zero downtime, or zero vulnerability.

19 Conclusion

The project has evolved from a visually strong university MERN demonstration into a comprehensive AI-assisted recovery platform with explicit privacy boundaries, secure sessions, transactional claims, durable background work, multilingual search/chat, internal regional location intelligence, explainable matching, human AI oversight, accessible task-first UI, and public-launch documentation.

The most important design principle is that AI increases discoverability and assists users but does not replace people in ownership, enforcement, privacy, or handover decisions. With the external deployment and institutional approval gates completed, the system is suitable for a controlled university public launch and ongoing operational improvement.

20 Document references

- README.md

- SECURITY.md
- DEPLOYMENT.md
- MIGRATION.md
- OPERATIONS.md
- VERIFICATION.md
- PROJECT_COMPLETION_MATRIX.md
- PRODUCTION_CERTIFICATION_STATUS.md
- docs/academic/SRS.md
- docs/academic/SOFTWARE_DESIGN_DOCUMENT.md
- docs/academic/ER_AND_DATA_DICTIONARY.md
- docs/academic/TEST_PLAN_AND_CASES.md
- docs/academic/DPIA_AND_RISK_ASSESSMENT.md
- docs/api/openapi.yaml
- docs/public/
- docs/manuals/
- docs/operations/
- docs/compliance/